

100+ Review Questions for CompTIA's SecOT+ Exam



This document is designed to help others prepare for the SecOT+ exam.

The official exam releases in November 2026 with the beta exam in early summer 2026.

The review questions are split into six categories as defined by the official exam requirements.

1. OT Systems and Safety Foundations
2. OT Risk Management
3. OT Threat Intelligence
4. OT Cybersecurity Architecture, Design, and Engineering
5. OT Security Operations
6. OT Incident Management

OT Systems and Safety Foundations

1. How does the primary goal of OT cybersecurity differ from the primary goal of IT cybersecurity?

- a. OT prioritizes data confidentiality; IT prioritizes physical safety
- b. OT prioritizes physical safety; IT prioritizes data confidentiality
- c. OT prioritizes plant operations; IT prioritizes data integrity
- d. The primary goal of OT cybersecurity and IT cybersecurity are the same.

2. What type of PPE (Personal Protection Equipment) would be considered mandatory to ensure personnel safety when working in high-voltage electrical panels?

- a. Respirators and chemical-resistant aprons
- b. Steel-toed boots and high-visibility vests
- c. Hard hat and safety glasses
- d. Arc flash suits, insulated gloves, and face shield

3. What does SIL stand for in industrial safety?

- a. System Integration Locator
- b. Safety Integrity Level
- c. Secure Industrial Logic
- d. Secure Integrity Lockout

- 4. During an active cybersecurity incident in a manufacturing plant, which of the following takes precedence?**
- a. Securing forensic data
 - b. Plant uptime
 - c. Human safety
 - d. Internal and external communication
- 5. What is a Programmable Logic Controller (PLC)?**
- a. System which monitors and controls equipment in the real world
 - b. A server used to store and archive historical plant data
 - c. A graphical interface for human operators to monitor the plant environment
 - d. A network switch designed for industrial protocols like Modbus and S7
- 6. According to the Purdue Model, which of the following types of systems lives at Level 0?**
- a. Physical process devices such as sensors, actuators, and motors
 - b. Basic control devices such as PLCs and RTUs
 - c. Plant supervisory systems such as HMIs
 - d. Business logistics servers in the IT enterprise
- 7. Which of the following would be used to update the firmware and/or logic on a PLC?**
- a. OWS
 - b. EWS
 - c. SIS
 - d. DCS
- 8. What is the primary function of a data historian?**
- a. Update the firmware on PLCs
 - b. Make backups of all assets on the OT/ICS network
 - c. Store time-series data for reporting and analysis
 - d. Accept orders from clients to forward to OT for production
- 9. Why is active scanning most often prohibited from being used on OT/ICS networks?**
- a. Considered too expensive
 - b. Requires Internet access which is prohibited in OT/ICS
 - c. Can cause availability and/or performance issues
 - d. Active scanning is actually allowed in all OT/ICS networks

10. Which of the following is the most commonly used programming language for PLCs?

- a. Ladder logic
- b. Structured text
- c. Function Block Diagram
- d. Instruction List

11. What is the correct order for the PLC “Scan Cycle”?

- a. Housekeeping -> Input Scan -> Output scan -> Program execution
- b. Program execution -> Output scan -> Housekeeping -> Input scan
- c. Output scan -> Input scan -> Program execution -> Housekeeping
- d. Input scan -> Program execution -> Output scan -> Housekeeping

12. Which of the following represents the digital I/O?

- a. 0, 1
- b. 0 – 65,535
- c. 80, 443, 1433
- d. 102, 502, 44818

13. What is the Set Point (SP)?

- a. The maximum physical limit of a machine
- b. The desired or target value of a process variable
- c. The time it takes for a PLC to complete one scan cycle
- d. The measured state of a process being controlled

14. Which critical infrastructure sector relies heavily on Building Management Systems (BMS) more than the others?

- a. Oil and Gas
- b. Power generation
- c. Commercial facilities
- d. Water/wastewater

15. What does the acronym ICS stand for?

- a. Industrial Control System
- b. Integrated Control Security
- c. Internal Communications Security
- d. Intelligent Control System

16. Which is a unique challenge in water/wastewater environments?

- a. Requires high-speed fiber optic communication lines
- b. Requires 5G connectivity for all installed sensors to accommodate for local interference generated by alternating VFDs
- c. It cannot use Ethernet due to the moisture in the physical environment
- d. Pumping stations are often geographically dispersed and require low-bandwidth radio communication

17. Which of the following would be considered a “ruggedized” piece of equipment?

- a. Built to withstand environmental extremes
- b. Designed with military-grade communication protocols for security
- c. Hardened operating systems with Zero Trust built-in to the OS
- d. Physically secured behind a minimum of three (3) physical security controls to prevent theft

18. According to the Purdue Model, which level would an anti-malware update server hosted between the IT and OT networks reside?

- a. 4
- b. 3.5
- c. 3
- d. 2.5

OT Risk Management

19. A manufacturing plant loses production capabilities due to the IT network being compromised with ransomware. Which metric would be used to measure the maximum acceptable amount of downtime measured in time?

- a. Recovery Time Objective (RTO)
- b. Mean Time to Repair (MTTR)
- c. Recovery Point Objective (RPO)
- d. Maximum Tolerable Downtime (MTD)

20. Which compliance requirements are enforced in North America for environments responsible for power generation and transmission?

- a. NERC CIP
- b. ISO 27001/27002
- c. NIST SP 800-82
- d. ISA/IEC 62443

21. Which of the following responsibilities would be filled by an owner's executive leadership?

- a. Configuring firewall rules for the IT/OT DMZ
- b. Escorting third-party vendors through the shop floor
- c. Managing the OT SOC when looking for suspicious network activity
- d. Establishing the organization's level of risk tolerance and providing support

22. Which of the following US government institutions issues security directives for both pipeline and rail operators?

- a. FDA
- b. TSA
- c. EPA
- d. SEC

23. What does the 'A' in a RACI matrix stand for?

- a. Administrator
- b. Assessor
- c. Accountable
- d. Accessible

24. What is the primary function of a Risk Register in OT environments?

- a. Track all assets on the network, including vendor make, model and firmware version
- b. List all identifies risks in the environment for tracking risk owners and remediation status
- c. To monitor for security issues identified through network security monitoring
- d. Create a supportive learning environment for team members were learning about different aspects of OT/ICS cybersecurity

25. What is the formula for calculating risk?

- a. $\text{Risk} = \text{Threat} \times \text{Vulnerability} \times \text{Impact}$
- b. $\text{Risk} = \text{Asset Value} / \text{Threat}$
- c. $\text{Risk} = (\text{Threat} \times 2) + (\text{Impact} \times 2)$
- d. $\text{Risk} = \text{Likelihood} + \text{Time} \times \text{Impact}$

26. Which of the following acts as an internationally accepted standard for securing OT/ICS environment from cybersecurity risks?

- a. PCI
- b. ISO 27001/27002
- c. NIST SP 800-153
- d. ISA/IEC 62443

27. In the context of risk variables, what is a "Vulnerability"?

- a. A malicious actor trying to cause some level of harm
- b. The financial cost of a breached system when there is an impact
- c. A weakness in an information system, procedure, or control that could be exploited by a threat
- d. The probability that an event will occur within a specific time frame

28. Why is communication an important part of the Change Management process?

- a. Stakeholders will understand when operations will be impacted and how
- b. It is legally mandated by the SEC
- c. It allows the organization to coordinate activities with its customers
- d. Communication is key to ensuring that any associated change does not fail

29. What is Factory Acceptance Testing (FAT)?

- a. Phishing awareness campaign emails sent to factory team members
- b. Physical pressure testing on a specific piece of equipment for stress testing
- c. Testing conducted at a manufacturer's facility to ensure it meets specifications
- d. Point in time when the customer review initial contacts and equipment specifications prior to purchase

30. What is the primary goal of Change Management in OT/ICS environments?

- a. Ensure that blame falls on IT when a change fails
- b. To speed up implementations by bypassing required testing
- c. Ensure all changes are evaluated, tested, approved, and documented
- d. To prevent changes from ever occurring in the OT environment

31. What is the role of the Change Advisory Board (CAB)?

- a. To review all reviews of PLC logic prior to being deployed to Production
- b. To negotiate pricing and contractual requirements with outside parties
- c. To perform a review of all proposed network infrastructure before implementation
- d. To approve or reject proposed changes which could impact the OT environment

32. A large LNG port facility has received equipment on-site prior to the commissioning of the facility. The on-site team needs to review the equipment and ensure it meets their requirements. Which of the following would the on-site team perform at this point?

- a. SAT
- b. FAT
- c. CAT
- d. PAT

33. An auditor is performing a physical walkthrough of a manufacturing plant and observes that most PLCs on the shop floor have their key switch placed in the 'Remote Run' position. What is the resulting documentation referred to as?

- a. A risk acceptance form
- b. A zero-day risk register
- c. An audit finding
- d. A Service Level Agreement (SLA)

- 34. Which framework was established by the United States government and defines six phases of cybersecurity – Identify, Protect, Detect, Respond, Recover, and governance?**
- a. NIST 800-82
 - b. ISA/IEC 62443
 - c. ISO 27001/27002
 - d. NIST CSF
- 35. A risk assessment identifies that there is currently no network security monitoring being performed in a water treatment plant. The owner of the facility determines that the cost of deploying network security monitoring is too great when compared to the probability of an attacker impacting the OT network. Which type of risk strategy is this considered?**
- a. Risk acceptance
 - b. Risk avoidance
 - c. Risk transference
 - d. Risk mitigation
- 36. A manufacturing plant recently had operations come to a stand still as the result of a ransomware attack on the IT network. The ransomware not only impacted IT assets but spread to the OT network. To prevent future similar attacks, a firewall was deployed between the IT and OT networks. This type of activity is considered what type of risk strategy?**
- a. Risk acceptance
 - b. Risk avoidance
 - c. Risk mitigation
 - d. Risk transference

OT Threat Intelligence

- 37. Which of the following threat intelligence frameworks on focusing on the relationships between the Adversary, Capability, Infrastructure, and Victim?**
- a. The Cyber Kill Chain
 - b. MITRE ATT&CK for ICS
 - c. ICS4ICS
 - d. The Diamond Model
- 38. In a recent cybersecurity incident, an industrial company was targeted by a hacker. At one point, the attacker sent malware via email to employees of the industrial company. According to the Lockheed Martin Cyber Kill Chain, which phase occurred?**
- a. Weaponization
 - b. Delivery
 - c. Reconnaissance
 - d. Actions on Objectives
- 39. In 2010, the first case of ICS-specific malware used to impact and destroy physical equipment was reported. The name of this malware was what?**
- a. TriSIS/TRITON
 - b. BlackEnergy2
 - c. Stuxnet
 - d. Industroyer/CrashOverride
- 40. In the context of OT threat intelligence, TTP stands for what?**
- a. Tactics, Techniques, and Procedures
 - b. Targeted Threat Protocols
 - c. Time to Patch
 - d. Technical Threat (Response and) Protection
- 41. What is the primary function of an ISAC?**
- a. To prosecute cyber criminals impacting OT/ICS environments
 - b. Review PLC logic code for the presence of malicious code prior to implementation
 - c. Store information about each asset on the OT/ICS network such as vendor make, model, and firmware version
 - d. Facilitate sharing of threat intel between member organizations

- 42. A manufacturing environment had its remote access solution compromised by a cyber attacker which targeted the company for espionage. The attacker targeting the environment was more than likely what type of attacker?**
- a. Hacktivist
 - b. Script kiddie
 - c. State actor
 - d. Ransomware operator
- 43. Which classification system for vulnerabilities provides a standardized numerical scoring system for rating the risk associated with a specific vulnerability?**
- a. MITRE ATT&CK for ICS
 - b. CVSS
 - c. STIX
 - d. TAXII
- 44. In 2017, a state adversary compromised the Safety Instrumented System (SIS) of a petrochemical facility in the Middle East. The incident was known as TriSIS/TRITON. The state adversary behind the attack was known as what?**
- a. Sandworm
 - b. Fuzzy Bear
 - c. Scattered Spider
 - d. Shattered Spider
- 45. The Shodan platform created by Jonathan Mattherly could be used to discover which of the following?**
- a. Unauthorized 5G connections dropped in the plant network by a contractor
 - b. Assets that are exposed directly to the Internet
 - c. Personal smartphones that are connected to engineering workstations without permission
 - d. USB drives compromised with malware

- 46. Jennifer is an OT SOC analyst that primarily focuses on using Indicators of Compromise (IOCs) such as known malicious IP addresses, file hashes, and domain names. These types of IOCs are considered which type of threat intelligence?**
- a. Strategic intelligence
 - b. Tactical intelligence
 - c. Operational intelligence
 - d. Technical intelligence
- 47. The ICS-specific malware known as Industroyer and CrashOverride was responsible for what OT environment impact?**
- a. Power blackout
 - b. Water complete loss
 - c. Water low pressure
 - d. Sewage spills in public locations
- 48. Which of the following documents the TTPs of known incidents with a primary focus on enumerating what attackers do once they've gained initial access to an OT network?**
- a. MITRE ATT&CK for ICS
 - b. CVSS
 - c. STIX
 - d. TAXII
- 49. Which piece of malware was used to turn off heating in 600 apartment building in the middle of winter in Ukraine in January 2024?**
- a. Stuxnet
 - b. TriSIS
 - c. CrashOverride
 - d. FrostyGoop
- 50. The Cyber Av3ngers group loosely aligned with Iranian state interested targeted Unitronics devices that were exposed to the Internet because the devices were made in Israel. The Cyber Av3ngers is an example of what type of attacker?**
- a. State adversary
 - b. Hacktivist
 - c. Script kiddie
 - d. Ransomware operator

51. Which cybersecurity incident impacted the longest gasoline pipeline in the United States, taking the pipeline down for 10 days, and resulting in the TSA issuing their Security Directives for pipeline and rail operators?

- a. Stuxnet
- b. Triconex
- c. Colonial
- d. Oldsmar

52. Which type of backup captures the entire state of the operating system, applications, and files at a specific point in time?

- a. System image
- b. Incremental file backup
- c. Differential file backup
- d. Cloud-only synchronization

53. What is the #1 attack vector that cyber attackers use to gain access to the OT network?

- a. Internet-exposed assets
- b. Remote access architecture
- c. Directly from the IT network
- d. Vulnerable web server in the DMZ

54. A large manufacturing environment just began a multi-year long project to deploy a solution which provides encryption and mutual authentication between assets on the OT network. Which of the following are they deploying?

- a. Physical keys used to lock cabinets in the plant
- b. Privileged Access Management (PAM)
- c. Network Security Monitoring (NSM)
- d. Public Key Infrastructure (PKI)

OT Cybersecurity Architecture, Design, and Engineering

55. The director for OT cybersecurity at one of the largest ports in the country wants to deploy a system between IT and OT that uses physics to ensure data can only be sent in one direction. Which of the following would be deployed to meet the director's needs?

- a. Data diode
- b. Unidirectional gateway
- c. Firewall
- d. Layer 3 switch

56. What is Multi-Factor Authentication (MFA)?

- a. Requiring a user to login with two (or more) unique passwords
- b. Allowing a user to login to multiple engineering workstations at the same time
- c. Use network security monitoring to provide multiple scans of traffic when looking for suspicious and/or malicious traffic
- d. Forcing a user to use two or more separate forms of evidence when logging in

57. Which of the following best describes a DMZ?

- a. A physical area within the plant which requires team members to wear PPE
- b. A completely air-gapped OT network which does not connect to any other type of network
- c. A buffer segment between the IT and OT networks which houses shared services
- d. The zone where all Level 0 assets reside to ensure security of all sensors, actuators and other equipment

58. The IT/OT DMZ is represented by which layer of the expanded Purdue Model?

- a. 4
- b. 3.5
- c. 3
- d. 2.5

59. Which of the following best describes the concept of “Defense in Depth”?

- a. Relying on a single security control such as a firewall between IT and OT
- b. Configuring security monitoring on each PLC in the plant
- c. Ensuring that all devices on the OT/ICS network are ruggedized
- d. Implementing multiple cybersecurity controls, assuming that at least one control will fail

60. Which of the following physical security controls can be used to prevent tailgating?

- a. A bollard
- b. A mantrap
- c. A USB blocker
- d. A HAZMAT suit

61. What is one argument against deploying MFA to protect OT assets?

- a. MFA could prevent an engineer from reviewing PLC logic prior to deployment
- b. MFA tokens can generate electrical interference
- c. Operators share mobile phones in OT which makes unique MFA tokens impossible
- d. MFA could delay an operator from responding in an emergency situation

62. Which of the following enforces the idea of providing users and systems with only the specific access and permissions they need to do their job – no more, no less?

- a. Defense in Depth
- b. Principle of Least Privilege
- c. The Pareto Principle
- d. Resilience Fundamentals

63. Which of the following ensures that any activity on the OT network can be tracked back to a specific individual?

- a. Least privilege
- b. Interoperability
- c. Accountability
- d. Resilience

64. Which architecture is described in ISA/IEC 62443 to segment the OT network into smaller segments shared by hosts with the same security requirements?

- a. Zones
- b. Conduits
- c. Subnets
- d. VLANs

65. Which of the following architecture designs assumes that the OT network is compromised and requires strict verification of each attempted network connection?

- a. Zero Trust
- b. Hub-and-Spoke
- c. IT/OT DMZ
- d. Least Privilege

66. Which of the following lessons was highlighted by the TriSIS/TRITON incident?

- a. Remote access applications like TeamViewer provide a common attack vector for threat actors
- b. OT assets can become exposed directly to the Internet where they can be found and targeted by attackers
- c. Safety Instrumented Systems should be air-gapped and not connected directly to the OT network
- d. Employees should not be allowed to access email from within the OT network

67. The main goal of physical barriers such as fences and bollards is to do what?

- a. To delay unauthorized physical access
- b. To prevent wireless signals from entering a facility
- c. To prevent wireless signals from leaving a facility
- d. To ensure there are plenty of options for electrical grounding

68. CCTV surveillance cameras are considered what type of security control?

- a. Detective
- b. Preventative
- c. Technical
- d. Management

69. Why are routine inspections of OT cabinets and server racks required in OT environments? Select the best answer.

- a. Meet requirements for regular inspection of dust and particulate accumulation
- b. To ensure that network speeds continue to be met on a continual basis.
- c. Unauthorized devices such as 5G modems can be deployed to the network.
- d. To build an asset register from scratch.

70. In physical security, CPTED stands for which of the following?

- a. Cyber Physical Threat Elimination Directives
- b. Crime Prevention Through Environmental Design
- c. Critical Process Technical Evaluation Data
- d. Control Panel Tamper Evident Device

71. What is the purpose of the physical “air gap”?

- a. To ensure adequate airflow around OT assets such as PLCs and HMIs
- b. To prevent any outside physical or logical network connections into the OT network
- c. To separate the IT team from the OT team
- d. To continually measure atmospheric pressure in sensitive areas of the plant environment

72. As part of its hardening plan for OT assets, the OT cybersecurity team in a water treatment facility implemented a control that checks the cryptographic signature of the bootloader, OS kernel, and drivers on all of its engineering and operator workstations. Which of the following controls did the team deploy?

- a. Zero Trust
- b. Secure Boot
- c. Air Gapping
- d. Allowlisting

73. Which of the following can be used to help ensure malicious firmware updates cannot be made by an unauthorized attacker with access to the OT network?

- a. Setting a PLC keyswitch to “Read Only”
- b. Setting a PLC keyswitch to “Remote Program”
- c. Setting a PLC keyswitch to “Secure Mode”
- d. Setting a PLC keyswitch to “Run Mode”

74. What is the primary advantage of allowlisting over traditional anti-malware solutions in an OT environment?

- a. Allowlisting can be automatically updated without human intervention
- b. Allowlisting can scan for abnormalities much faster
- c. Allowlisting is much more effective at preventing malicious software from running on a system
- d. Allowlisting is much more effective at allowing team members to surf the Internet securely from the OT network

OT Security Operations

75. What is the primary benefit of maintaining a complete and accurate OT asset register?

- a. Provides OT and IT cybersecurity team members with information about the information that's important when investigating alerts
- b. Assists the Operations team members with automating upgrades to legacy systems to speed deployment and limit plant downtime
- c. Prevents the theft of OT assets such as PLCs, HMIs, and engineering workstations
- d. Lowers the overall consumption of energy consumed by a plant over time

76. Why is active scanning in OT/ICS environments often prohibited?

- a. It is considered illegal by most local and state government entities
- b. It can cause interruptions in operations by impacting legacy assets, creating adverse network conditions, or other issues
- c. It is only considered effective in IT networks
- d. It requires a physical laptop to be connected directly to the OT network at Level 0 according to the expanded Purdue Model

77. Which of the following methods for building an asset register presents the most physical risk to team members?

- a. Walking the plant
- b. Active scanning
- c. Passive network sniffing
- d. Review project files and other documentation

78. Which of the following details in an asset register is the MOST important in determining the presence of security vulnerabilities on an OT asset?

- a. Firmware version
- b. Last update date
- c. Next planned update date
- d. Asset owner

79. Which of the following would be considered a transitory cyber asset?

- a. PLC
- b. HMI
- c. Contractor laptop
- d. Engineering workstation

80. Chewy is reviewing a system that documents all of the software components within a software application used within the OT network. He is also using the system to determine if the software has any known vulnerabilities. Which of the following is Chewy reviewing?

- a. ISAC
- b. SIS
- c. SBOM
- d. ICS4ICS

81. Which of the following protocols should be monitored to determine when new assets are added to the OT network? Select the best answer.

- a. MAC
- b. ARP
- c. HTTP
- d. ICMP

82. Lee Hsu identifies that a PLC on the shop floor had its programming logic recently changed, but that the change was not approved by the Change Control Board. Which of the following should occur next?

- a. Law enforcement should be notified
- b. Ensure the asset register is updated
- c. Follow incident response procedures to investigate the cause
- d. Disconnect the PLC from the network and notify the plant manager

83. Which of the following is a challenge of using a traditional IT SEIM platform in an OT/ICS environment?

- a. Lack of correlation rules for OT-specific activity and protocols such as DNP3 and Modbus
- b. It cannot store collected data past 24 hours
- c. It requires operators to understand how to convert IT to OT
- d. It can falsely identify OT network protocols as malicious and actively block the traffic, potentially interfering with plant operations and safety

84. Why is SOAR often not leveraged in OT environments?

- a. It could take an action that interferes with safety and operations
- b. It is deemed illegal to use in most environments by the SEC
- c. Its technology stack does not allow it to be used in OT/ICS environments
- d. ISA/IEC 62443 specifically states that SOAR implementations are prohibited from use in OT/ICS environments

85. Lorena is performing a security investigation by reviewing time-series data of physical processes in the plant. Which of the following is she reviewing?

- a. PLC
- b. CCTV
- c. Data historian
- d. Engineering workstation

86. Carlos is reviewing the logs from the firewall deployed between the IT and OT network and notes that there are blocked packets on TCP ports 80, 443, 102, 502, 44818 and more. What type of attack might this indicate?

- a. Password spraying
- b. Port scanning
- c. Shodan enumeration
- d. Social engineering

87. Which of the following network ports is associated with Modbus?

- a. TCP 102
- b. TCP 443
- c. TCP 502
- d. TCP 8888

88. Which of the following tools would be used by a security analyst to read a PCAP?

- a. Nmap
- b. Wireshark
- c. Metasploit
- d. Nikto

89. Jennifer is monitoring security alerts for the OT network when she receives an alert that an HMI was detected for attempting an outbound SSH connection to a public IP address. Which of the following should she do next?

- a. Investigate the reason for the traffic
- b. Immediately disconnect the HMI from the network
- c. Notify an Operations team member to replace the HMI hardware
- d. Mark the alert as a false positive since HMIs cannot be compromised

90. Which of the following should not be deployed in an OT/ICS environment as it could actively block network traffic which is required to ensure safety and operational availability?

- a. CUPS
- b. CAPS
- c. IDS
- d. IPS

OT Incident Management

91. Which of the following is the first phase of the PICERL incident response model?

- a. Preparation
- b. Planning
- c. Physical
- d. Process

92. The ICS4ICS framework was adapted from which of the following?

- a. The NIST Cybersecurity Framework (CSF)
- b. MITRE ATT&CK for ICS
- c. FEMA's Incident Command System (ICS)
- d. ISA/IEC 62443

93. According to the PICERL model, which of the following phases involves removing an attacker's access to the environment?

- a. Identification
- b. Containment
- c. Eradication
- d. Lessons Learned

94. Why does the ICS4ICS framework work well in OT/ICS environments?

- a. It mandates exactly which network security monitoring tools are to be used
- b. It uses standardized language shared in common between OT cybersecurity responders and physical plant responders
- c. It strictly prohibits involvement of IT team members
- d. It relies on highly available tools that are accessible from the cloud

95. Herbert is conducting an exercise with team members that were just involved with responding to an OT cybersecurity incident in their refinery. The team is working to identify what went well during the response and, more importantly, are working to identify opportunities for improvement. Herbert and the team are currently conducting what type of activity?

- a. Tabletop exercise
- b. Lessons learned
- c. Security awareness training
- d. OT threat landscape briefing

96. What marks the official end of the Recovery phase?

- a. The attacker is caught
- b. The first impacted system is restored
- c. The malware used by the attacker has been identified
- d. The plant manager acknowledges that normal, secure operations have been fully restored and validated

97. During OT recovery, why could restoring a PLC's logic from an older backup be potentially dangerous?

- a. Older backups could put increased stress on the PLCs hardware resulting in slow performance
- b. SEC requirements do not allow backups older than one week to be used in most OT/ICS environments globally
- c. The older backup could take too long to restore, introducing safety and operational availability issues
- d. Unsafe actions might be taken by the PLC if physical process parameters, like a storage tank's level, have changed since the older backup was taken

98. What is mandatory reporting?

- a. The requirement to report any relevant cybersecurity incident to the appropriate authorities
- b. Guidance provided by the plant manager to the IT cybersecurity team members when an incident occurs
- c. Requires all OT team members to provide a report on the incident, their understanding of what occurred and any identified opportunities for improvement
- d. OT cybersecurity incidents are required to be reported to local news media so that the general public can be made aware of the situation

99. Which of the following is considered the most secure form of Eradication and ensure an attacker no longer has control over an asset?

- a. Running a full scan using the local anti-malware solution rather than a quick scan
- b. Manually deleting any artifacts left by the attackers on the asset
- c. Changing all passwords associated with the asset, including any and all hardcoded passwords
- d. Wiping the system and restoring from a known-good, trusted image

- 100. Pierre is an analyst on the OT SOC and notices a sudden and immediate surge in SMB activity. What type of attack could this indicate?**
- a. An unauthorized vulnerability scan using Nessus
 - b. Normal polling of a PLC by an HMI
 - c. A potential ransomware infection moving through the environment
 - d. Completion of a successful backup of a PLC
- 101. Carlos is monitoring the OT SOC console when he receives an alert from a Windows-based HMI reporting that the file hash associated with an important system DLL changed. What could this indicate?**
- a. The file had been altered
 - b. The file was successfully backed up
 - c. The file was not successfully backed up
 - d. The HMI has lost connectivity to the PLC that it monitors and controls
- 102. Which of the following types of traffic would be considered abnormal for an OT network?**
- a. An HMI connecting to a PLC
 - b. An engineering workstation performing DNS resolution
 - c. SQL Server traffic via TCP 1433 between data historians
 - d. An ARP broadcast from an HMI that was just powered on
- 103. Setsuko is performing a review of an OT firewall. To help expedite the review, she exports the firewall events to a file and uploads the results to ChatGPT. Once uploaded, she prompts ChatGPT to complete the review for her. What's wrong with this situation?**
- a. Nothing.
 - b. OT firewalls don't generate events that can be reviewed.
 - c. Sensitive data should not be uploaded to cloud platforms such as ChatGPT.
 - d. GenAI can't perform such reviews.
- 104. What is the primary focus of performing a Root Cause Analysis (RCA)?**
- a. Identify the attacker responsible for the breach
 - b. Calculating the financial cost of any associated downtime
 - c. Find the exact cause of how the incident occurred and address the issue
 - d. Determining the geographic location of the attacker

- 105. In digital forensics, what is the “Chain of Custody?”**
- a. A physical security lock for cabinets in an OT data center
 - b. Individual locks which can be inserted into each empty Ethernet port
 - c. A network topology showing all connections allowed through a firewall which accompanies the asset register
 - d. A record of custody, transfer, and analysis of digital evidence
- 106. How often should an organization perform tabletop exercises?**
- a. Only when a new plant manager or OT CISO is hired
 - b. After a security incident occurs within the plant
 - c. Annually or when there is a significant change to the environment or threat landscape
 - d. Once every five years
- 107. Which of the following cyber security exercises are usually not conducted in OT environments due to safety and availability concerns?**
- a. Tabletop exercises
 - b. Penetration testing
 - c. Vulnerability assessments
 - d. Network security monitoring
- 108. Chris and Paul on the OT cybersecurity team for a refinery, have been working with an outside provider to negotiate a contract to bring in the outside provider in the event of a cybersecurity incident. The contract will have defined SLAs on requirements for assistance once the outside provider is notified of a potential incident. What are Chris and Paul working to establish?**
- a. Incident response retainer
 - b. Asset register
 - c. Incident Response Plan (IRP)
 - d. Vulnerability management program
- 109. What is the main difference between an Incident Response Plan (IRP) and an incident response playbook?**
- a. An IRP is for OT; A playbook is for IT
 - b. A playbook is for OT; An IRP is for IT
 - c. An IRP is high-level; a playbook has specific steps
 - d. An IRP is optional; a playbook is legally required

110. Which external party should be notified immediately in the event of an environmental chemical spill?

- a. The IT Helpdesk
- b. Local emergency services
- c. The OT SOC team members
- d. The corporate communications team

Answer Key

- 1. B
- 2. D
- 3. B
- 4. C
- 5. A
- 6. A
- 7. B
- 8. C
- 9. C
- 10. A
- 11. D
- 12. A
- 13. B
- 14. C
- 15. A
- 16. D
- 17. A
- 18. B
- 19. C

20. A
21. D
22. B
23. C
24. B
25. A
26. D
27. C
28. A
29. C
30. C
31. D
32. A
33. C
34. D
35. A
36. C
37. D
38. B
39. C
40. A
41. D
42. C
43. B
44. A
45. B

- 46. D
- 47. A
- 48. A
- 49. D
- 50. B
- 51. C
- 52. A
- 53. C
- 54. D
- 55. A
- 56. D
- 57. C
- 58. B
- 59. D
- 60. B
- 61. D
- 62. B
- 63. C
- 64. A
- 65. A
- 66. C
- 67. A
- 68. A
- 69. C
- 70. B
- 71. B

- 72. B
- 73. D
- 74. D
- 75. A
- 76. B
- 77. A
- 78. A
- 79. C
- 80. C
- 81. B
- 82. C
- 83. A
- 84. A
- 85. C
- 86. B
- 87. C
- 88. B
- 89. A
- 90. D
- 91. A
- 92. C
- 93. C
- 94. B
- 95. B
- 96. D
- 97. D

- 98. A
- 99. D
- 100. C
- 101. A
- 102. B
- 103. C
- 104. C
- 105. D
- 106. C
- 107. B
- 108. A
- 109. C
- 110. B